

# Pramo Jewels

## Data Encryption Policy

Document ID: PJ-ENC-001  
Version: 1.0  
Status: Approved for Development

| Field    | Value                                                                              |
|----------|------------------------------------------------------------------------------------|
| Project  | Pramo Jewels Premium E-Commerce Platform                                           |
| Purpose  | Define encryption standards for protecting customer, business and operational data |
| Audience | Security Team, Developers, DevOps, Database Administrators                         |
| Version  | 1.0                                                                                |

### Encryption Standards

| Data Type                    | Protection Standard                          |
|------------------------------|----------------------------------------------|
| Passwords                    | Argon2id (preferred) or Bcrypt hashing       |
| API Traffic                  | TLS 1.2+ / HTTPS                             |
| Sensitive Database Fields    | AES-256 encryption at rest                   |
| Backups                      | AES-256 encrypted before storage             |
| Secrets & API Keys           | Dedicated secret management; never hardcoded |
| Object Storage               | Encrypted at rest with managed keys          |
| Webhook Payload Verification | HMAC signature validation                    |

### Encryption in Transit

All communication between browsers, APIs, payment gateways, courier partners and internal services must use HTTPS with modern TLS configurations.

### Encryption at Rest

Sensitive customer information, authentication tokens where stored, backups and media metadata should be encrypted using strong industry-standard algorithms.

### Key Management

Encryption keys must be stored separately from encrypted data, rotated periodically, access-controlled and never committed to source control.

### Credential Management

Use environment variables or managed secret stores. Rotate credentials regularly and revoke compromised credentials immediately.

## **Data Classification**

Classify data as Public, Internal, Confidential and Restricted. Apply stronger encryption and access controls to Confidential and Restricted information.

## **Logging**

Never log passwords, OTPs, payment credentials or full authentication tokens. Mask sensitive values in logs and monitoring tools.

## **Compliance**

Follow OWASP guidance, secure development practices and applicable privacy regulations. Review cryptographic standards annually.

## **Audit & Governance**

Track key rotations, encryption failures and privileged access to encrypted data. Perform periodic audits and recovery testing.

## **Acceptance Criteria**

All sensitive data is encrypted appropriately, keys are managed securely, transport encryption is enforced and security audits confirm policy compliance.